ISCTE – Instituto Universitário de Lisboa

Escola de Tecnologias e Arquitetura

SEGURANÇA DE REDES E SISTEMAS DE INFORMAÇÃO

Relatório do Projeto – Parte 1 (Teórica)

Middleware Adaptativo de Privacidade e Redução de Dados em Sistemas de Informação

Implementação de um Modelo Inspirado em PADRES/PRIPRO para Proteção de Dados e Segurança

---

Elaborado por:

João Barradas 146757
Lucas Martins 149104
Malam Sanhá 125754
Marta Gaspar 104994

Docente

Daniel Maximino Caçador

Lisboa, 31 de outubro de 2026

Resumo

Índice

Resumo i

Capítulo 1. Introdução 1
1.1. Contexto e Motivação 1
1.2. Definição do Problema 2
1.3. Objetivos do Trabalho 2

Capítulo 2. Enquadramento Regulatório e Normativo 3
2.1. Regulamento Geral sobre a Proteção de Dados (RGPD) 3
2.2. Diretiva NIS2 4
2.3. Implicações para o protótipo 4

Capítulo 3. Estado da Arte e Trabalhos Relacionados 7
3.1. Análise dos Modelos Base 7
3.2. Análise Comparativa de Trabalhos Relacionados 7

Capítulo 4. Formalização Matemática 9
4.1. Nível de Informação: Entropia de Shannon 9
4.2. Taxa de Redução de Payload (ΔD) 9

Capítulo 5. Arquitetura Proposta para o Middleware 11
5.1. Perfis de Acesso Adaptativos 11

Capítulo 6. Conclusões e Trabalhos Futuros 13

Referências Bibliográficas 15

CAPíTULO 1

Introdução

A crescente integração entre sistemas de informação tem aumentado a circulação de dados através de interfaces de programação de aplicações (APIs), em particular de serviços HTTP/REST. Embora esta partilha permita automatizar processos e disponibilizar informação a diferentes entidades, uma resposta pode conter atributos que não são necessários para todos os seus destinatários. A exposição desses atributos aumenta o risco para a privacidade e pode também implicar a transmissão de um volume de dados superior ao necessário.

Neste contexto, este trabalho propõe o desenvolvimento de um middleware/proxy de privacidade em Python, colocado entre os clientes e os serviços de backend. A camada intermédia deverá identificar o perfil associado ao pedido e adaptar a resposta antes de a devolver ao cliente. Deste modo, pretende-se aproximar o controlo de acesso da própria representação dos dados transmitidos, sem pressupor que todos os clientes autorizados necessitam da mesma informação.

1.1. Contexto e Motivação

Em ecossistemas de APIs RESTful, os mecanismos de autorização determinam frequentemente se um pedido pode aceder a um recurso, mas não adaptam necessariamente o conteúdo da resposta às necessidades concretas de quem o solicita. Assim, um consumidor autorizado a consultar um recurso pode receber dados pessoais identificáveis (PII) ou outros atributos sensíveis, mesmo quando apenas necessita de uma visão parcial ou de métricas consolidadas. A aplicação de uma política uniforme pode, por isso, favorecer a utilidade operacional à custa da minimização da informação divulgada.

A motivação do projeto é explorar uma abordagem intermédia que combine perfis de acesso com transformações do payload. Inspirado nos modelos PRIPRO/PRIADA, que orientam a gestão dinâmica de perfis de privacidade e a gestão de contexto em ambientes distribuídos [**1**], e PADRES, associado à redução de dados consciente da privacidade e à regulação de segurança [**2**], o middleware deverá adaptar a resposta a três perfis previstos na proposta: o Administrador recebe os dados necessários às suas funções e permissões; o Operacional/Analista recebe dados com mascaragem ou pseudonimização de atributos confidenciais; e o Público/Terceiros recebe informação agregada e reduzida. A aplicação destas transformações procura limitar a exposição de dados e, nos casos em que os campos são omitidos ou agregados, reduzir também o payload transmitido.

Esta abordagem exige considerar simultaneamente a proteção da informação e a sua utilidade. A transformação não deve remover dados necessários à finalidade legítima do

pedido, e a redução do payload não constitui, por si só, uma garantia de anonimização ou de conformidade regulatória. Por esse motivo, o trabalho enquadra a proposta nos princípios do RGPD e na resiliência dos sistemas de informação abordada pela Diretiva NIS2, e prevê avaliar o comportamento do protótipo através de testes funcionais e métricas de desempenho.

1.2. Definição do Problema

O problema central consiste na dificuldade de conciliar a disponibilização de informação útil com a limitação dos dados pessoais e do volume de informação transmitidos a cada consumidor. Uma decisão estática de permitir ou negar o acesso, incluindo uma política baseada em papéis (RBAC), pode não distinguir entre destinatários com necessidades diferentes perante o mesmo recurso. Como consequência, mesmo quando o acesso é legítimo, a resposta pode conter mais informação do que a necessária.

Pretende-se, por isso, estudar como um middleware pode usar o perfil associado ao pedido para aplicar políticas de transformação coerentes antes de encaminhar a resposta. A solução deverá articular a identificação do perfil, a seleção dos campos a manter ou transformar e a entrega da resposta adaptada. A sua avaliação deverá verificar se cada perfil recebe o tipo de informação esperado e medir o custo introduzido pela camada intermédia, incluindo latência e consumo de recursos, bem como a variação do tamanho do payload. O desafio está em reduzir a exposição e a transmissão de dados sem comprometer a correção funcional das respostas.

1.3. Objetivos do Trabalho

O objetivo geral é conceber e avaliar um protótipo de middleware/proxy que adapte respostas de APIs segundo perfis de acesso, combinando proteção da privacidade e redução de dados. Para o concretizar, o projeto divide-se em duas componentes:

- **Objetivo Teórico (Parte 1):** Rever abordagens de controlo de acesso adaptativo e de proteção da privacidade, enquadrar a proposta face ao RGPD e à Diretiva NIS2 e formalizar métricas para discutir a informação exposta, com base na Entropia de Shannon, e a redução do payload, através de ΔD.
- **Objetivo Prático (Parte 2):** Implementar um protótipo modular em Python, recorrendo a FastAPI ou Flask, que intercepte pedidos HTTP/REST e adapte as respostas para os perfis definidos. Validar funcionalmente as transformações e comparar o comportamento com e sem middleware, medindo a latência, o consumo de CPU e memória e o tamanho dos dados transmitidos.

O trabalho incide sobre um protótipo e a sua avaliação experimental; os resultados permitirão caracterizar a abordagem no cenário de teste, não constituindo por si só uma certificação de conformidade nem uma demonstração de adequação a ambientes de produção.

CAPíTULO 2

Enquadramento Regulatório e Normativo

A conceção de um middleware que intermedeia pedidos e respostas deve considerar tanto a proteção dos dados pessoais como a segurança e a resiliência dos sistemas de informação. Neste projeto, o Regulamento Geral sobre a Proteção de Dados (RGPD) é relevante quando os dados tratados permitem identificar diretamente ou indiretamente uma pessoa singular. A Diretiva NIS2, por sua vez, estabelece requisitos de gestão de riscos de cibersegurança para as entidades abrangidas pelo seu âmbito. Os dois instrumentos são complementares, mas têm objetivos e âmbitos de aplicação distintos: a existência do protótipo, por si só, não demonstra conformidade com nenhum deles.

2.1. Regulamento Geral sobre a Proteção de Dados (RGPD)

O RGPD estabelece princípios e obrigações aplicáveis ao tratamento de dados pessoais [**3**]. Para o middleware proposto, são particularmente relevantes:

- **Limitação das finalidades e minimização (Artigo 5.º, n.º 1, alíneas b) e c)):** Os dados devem ser tratados para finalidades determinadas e explícitas, e limitar-se ao que é necessário para essas finalidades. No protótipo, isto implica definir, por recurso e perfil, que campos são necessários, em vez de devolver automaticamente toda a resposta do serviço de backend.
- **Exatidão e limitação da conservação (Artigo 5.º, n.º 1, alíneas d) e e)):** Os dados devem ser exatos e conservados apenas durante o período necessário. Embora o middleware se concentre na resposta em trânsito, os registos e dados temporários que possa produzir também devem ser considerados na conceção e nos testes.
- **Integridade, confidencialidade e responsabilidade (Artigo 5.º, n.º 1, alínea f), e n.º 2):** O responsável pelo tratamento deve assegurar proteção adequada contra tratamento não autorizado ou ilícito e conseguir demonstrar o cumprimento dos princípios aplicáveis. A adaptação de respostas deve, portanto, ser acompanhada por controlos de acesso e por políticas verificáveis, não apenas por remoção de campos.
- **Proteção de dados desde a conceção e por defeito (Artigo 25.º):** As medidas técnicas e organizacionais devem ser integradas na conceção do tratamento e, por defeito, limitar a quantidade de dados, a extensão do tratamento, o período de conservação e a acessibilidade. A separação das respostas por perfil constitui uma possível medida técnica, desde que os perfis e as regras sejam definidos de forma adequada à finalidade.

- **Segurança do tratamento (Artigo 32.º):** As medidas devem ser adequadas ao risco e podem incluir pseudonimização e cifragem, mecanismos para garantir confidencialidade, integridade, disponibilidade e resiliência, bem como processos de teste e avaliação regulares. O artigo não prescreve uma tecnologia única: a escolha deve considerar o contexto, os riscos e o estado da técnica.

É importante distinguir as transformações previstas. A *mascaragem* pode ocultar parte de um valor numa resposta, mas não garante, por si só, que a pessoa deixe de ser identificável. A *pseudonimização*, nos termos do artigo 4.º, n.º 5, substitui identificadores por outros valores e exige que a informação adicional que permita atribuir os dados a uma pessoa seja mantida separadamente e protegida; os dados pseudonimizados continuam a ser dados pessoais quando a reidentificação é possível. A anonimização exige que a identificação deixe efetivamente de ser razoavelmente possível, o que depende também do contexto e de outros dados disponíveis. Assim, reduzir o tamanho do payload ou aplicar hashing não deve ser apresentado automaticamente como anonimização.

2.2. Diretiva NIS2

A Diretiva (UE) 2022/2555, conhecida como NIS2, procura estabelecer um nível elevado comum de cibersegurança na União Europeia [4]. A sua aplicação depende do âmbito definido na Diretiva e da legislação nacional que a transpõe; não se deve, por isso, assumir que qualquer serviço ou protótipo está automaticamente sujeito às mesmas obrigações. Para as entidades abrangidas, a Diretiva prevê responsabilidades de governação e medidas de gestão de riscos, tendo em conta a exposição a riscos, a dimensão da entidade e a probabilidade e gravidade dos incidentes.
O artigo 21.º identifica áreas de medidas de gestão de riscos, entre as quais o tratamento de incidentes, a continuidade das atividades, a segurança da cadeia de fornecimento, a segurança na aquisição, desenvolvimento e manutenção de sistemas, a avaliação da eficácia das medidas, políticas de criptografia, controlo de acessos e, quando adequado, autenticação multifator e comunicações seguras. A Diretiva não se reduz à proteção de dados pessoais: o seu foco inclui a disponibilidade e a resiliência dos sistemas e serviços.
No contexto do projeto, um middleware que recebe e reencaminha pedidos é também um componente cuja configuração e funcionamento devem ser considerados no modelo de ameaças. Uma política de filtragem pode reduzir a exposição de campos, mas não substitui medidas como autenticação robusta, validação dos tokens, proteção do tráfego, gestão segura de segredos, atualização de dependências, tratamento controlado de erros e preparação para falhas. A relevância e a proporcionalidade de cada medida devem ser avaliadas em função do cenário de utilização.

2.3. Implicações para o protótipo

O enquadramento regulatório traduz-se em requisitos de conceção e de validação, não numa declaração de conformidade:

- **Autorização antes da transformação:** o perfil deve ser obtido de uma credencial validada, e não aceite como um valor arbitrário fornecido pelo cliente. Pedidos sem autenticação ou autorização válida não devem receber dados do backend.
- **Políticas explícitas por perfil:** cada política deve indicar os campos permitidos, mascarados, pseudonimizados, omitidos ou agregados, de acordo com a finalidade prevista. A configuração deve seguir o princípio do menor privilégio e evitar que campos novos sejam expostos implicitamente.
- **Proteção do fluxo e dos componentes:** devem ser consideradas a proteção das comunicações, a gestão de credenciais e segredos, a validação de entradas e respostas e a divulgação mínima de informação em erros e registos.
- **Verificação funcional e de segurança:** os testes devem confirmar que cada perfil recebe apenas a resposta prevista, que pedidos inválidos ou não autorizados são rejeitados e que as transformações não alteram indevidamente os dados necessários à finalidade do serviço.
- **Avaliação do impacto:** além de verificar as respostas por perfil, a avaliação prática deverá medir a latência, o consumo de CPU e memória e o tamanho do payload antes e depois da transformação. Estas métricas caracterizam o protótipo, mas não medem, isoladamente, o cumprimento das obrigações legais.

Deste modo, o RGPD orienta sobretudo a necessidade e a forma do tratamento de dados pessoais, enquanto a NIS2 enquadra a gestão de riscos de cibersegurança e a resiliência das entidades abrangidas. A arquitetura proposta pode contribuir para objetivos relacionados com ambos, mas a avaliação de conformidade exigiria analisar o tratamento completo, os responsáveis envolvidos, o contexto operacional e as medidas organizacionais e técnicas aplicáveis.

CAPíTULO 3

Estado da Arte e Trabalhos Relacionados

A literatura científica tem proposto diversos esquemas para assegurar a privacidade e a eficiência na transmissão de dados.

3.1. Análise dos Modelos Base

A proposta deste projeto baseia-se na fusão e adaptação dos seguintes modelos de referência:

- **Modelo PRIPRO / PRIADA:** Focado na gestão de perfis de privacidade do utilizador e na adaptação dinâmica da informação com base em permissões e contexto [**1**].
- **Modelo PADRES:** Propõe esquemas de redução de dados e encriptação consciente da privacidade (*privacy-aware data reduction and encryption scheme*), promovendo a remoção ou agregação de atributos secundários para diminuir o tamanho dos dados transmitidos na rede [**2**].

3.2. Análise Comparativa de Trabalhos Relacionados

A Tabela 1 sistematiza a comparação entre abordagens tradicionais, os modelos base da literatura e o middleware adaptativo proposto neste trabalho.

TABELA 1. Comparação entre Abordagens de Privacidade e Proteção de Dados

Modelo / Abordagem	**Controlo de Acesso**	**Mascaragem**	**Redução (ΔD)**	**Adaptabilidade**
RBAC Tradicional	Estático	Não	Não	Baixa
Modelo PRIPRO	Dinâmico/ Perfis	Sim	Parcial	Média
Modelo PADRES	Regras/ Privacidade	Sim	Sim	Alta
Proposta (Middleware)	**Contextual Tokens**	**Sim (Dinam.)**	**Sim (ΔD)**	**Alta (Tempo Real)**

CAPíTULO 4

Formalização Matemática

Para avaliar de forma rigorosa o impacto do middleware tanto ao nível da privacidade como ao nível da eficiência da rede, são utilizadas duas métricas matemáticas fundamentais.

4.1. Nível de Informação: Entropia de Shannon

A Entropia de Shannon $H(X)$ mede a incerteza ou o grau de informação contido numa variável aleatória de dados X com possíveis resultados $\{x_1, x_2, \ldots, x_n\}$ e probabilidades $P(x_i)$ **[5]**:

$$H(X) = -\sum_{i=1}^{n} P(x_i) \log_2 P(x_i) \tag{4.1}$$

Quando o middleware aplica técnicas de mascaragem dinâmica, pseudonimização ou eliminação de campos sensíveis para os perfis de menor privilégio (ex.: Analista ou Público), a variabilidade e incerteza associadas aos dados revelados altera-se, permitindo quantificar formalmente a redução de informação exposta.

4.2. Taxa de Redução de Payload (ΔD)

A taxa de redução do tamanho dos dados transmitidos na rede (ΔD) quantifica a eficiência do esquema tipo PADRES em termos de poupança de largura de banda. Sejam S_{orig} o tamanho do payload original em bytes e S_{trans} o tamanho do payload transformado entregue ao cliente:

$$\Delta D = \left(1 - \frac{S_{trans}}{S_{orig}}\right) \times 100\% \tag{4.2}$$

A equação (4.2) demonstra a percentagem de carga útil omitida ou agregada. No perfil Público/Terceiros, prevê-se que $S_{trans} \ll S_{orig}$, resultando numa taxa ΔD elevada.

CAPíTULO 5

Arquitetura Proposta para o Middleware

O sistema atua como um proxy de segurança em Python intercetando pedidos entre clientes e serviços de backend.

5.1. Perfis de Acesso Adaptativos

O middleware processa as respostas dinamicamente segundo três perfis principais:

- **Perfil Administrador:** Recebe o conjunto de dados completo com permissões integrais de administração.
- **Perfil Operacional / Analista:** Recebe os dados com mascaragem automática e pseudonimização de atributos confidenciais.
- **Perfil Público / Terceiros:** Recebe apenas dados agregados e métricas consolidadas, minimizando o payload enviado.

CAPíTULO 6

Conclusões e Trabalhos Futuros

A formalização teórica apresentada neste relatório valida a viabilidade de combinar o controlo adaptativo por perfis (PRIPRO) com o esquema de redução de dados consciente da privacidade (PADRES). Como trabalhos futuros no âmbito da Parte 2 do projeto, proceder-se-á à implementação do protótipo em Python recorrendo às frameworks FastAPI/Flask, desenvolvendo scripts de benchmarking para medir latência (ms), consumo de CPU e memória.

Referências Bibliográficas

[1] Jefferson Cesconetto, Luis Arthur Silva, Francisco Bortoluzzi, Marcelo Navarro-Cáceres, Carlos Alberto Zeferino, and Villians R. Q. Leithardt. Pripro: Privacy profiles – user profiling management for smart environments. *Electronics*, 9(9):1519, 2020.

[2] Fábio Pereira, Pedro Crocker, and Villians R. Q. Leithardt. Padres: Tool for privacy, data regulation and security. *SoftwareX*, 17:100895, 2022.

[3] European Parliament and Council of the European Union. Regulation (eu) 2016/679 of the european parliament and of the council of 27 april 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data. Official Journal of the European Union, L 119, 4 May 2016, pp. 1–88, 2016.

[4] European Parliament and Council of the European Union. Directive (eu) 2022/2555 of the european parliament and of the council of 14 december 2022 on measures for a high common level of cybersecurity across the union (nis 2 directive). Official Journal of the European Union, L 333, 27 December 2022, pp. 80–152, 2022.

[5] Claude E. Shannon. A mathematical theory of communication. *Bell System Technical Journal*, 27(3):379–423, 1948.